

FortVault ISO 27001 Supporting Information Package

Document field	Value
Document owner	FortVault
Intended audience	FortVault's ISO 27001 implementation partner
Classification	Confidential
Status	Draft evidence package - management review required
Version	0.2
Date	August 28, 2026

Purpose

This package organizes the technical supporting information requested for the FortVault ISO/IEC 27001 implementation. It separates source-controlled evidence from operational evidence that must be collected from the production environment and operating procedures.

It does not establish ISO 27001 certification, production-control effectiveness, or evidence of a completed backup, restore, patch, or cloud-configuration review.

Evidence Index

Request	Source-controlled evidence	Operational evidence required
Testing and health checks	01-source-controlled-testing-health-and-security.md	Recent CI/test results and a sanitized health-audit result for each production environment
AWS / Google Cloud setup	Repository references to AWS Secrets Manager integration where implemented	Management-provided current-state summary and deployment diagram are included. Sanitized cloud-console exports remain required.
Backups	Durable-state ownership and recovery boundaries described in the custody technical overview	Management-provided schedules and retention are included. Encryption evidence, approved RPO/RTO, access review, and restore-test evidence remain required.
Logging	Application logging and sanitized health-configuration behavior	Central log destination, retention, access control, alerting, and representative redacted log evidence
TLS and encryption at rest	Application and MPC key-share protection mechanisms described in source evidence	TLS termination protocol/cipher policy, certificate management, storage/database/backup encryption settings, and key-management evidence
Endpoint OS and updates	None expected in product source code	Managed endpoint inventory, OS versions, patch policy, disk encryption, device management, endpoint protection, and compliance reports
GitHub README examples	03-readme-and-architecture-index.md and 05-component-readme-examples.md	Controlled repository access or a reviewed export of the selected files

Documents

- 1 01-source-controlled-testing-health-and-security.md records the implementation evidence reviewed from FortVault repositories.
- 2 02-operational-evidence-checklist.md lists the exact production and IT evidence needed to complete the response.
- 3 03-readme-and-architecture-index.md identifies safe README and architecture examples for sharing.
- 4 05-component-readme-examples.md provides sanitized, revision-bound examples from selected component READMEs.
- 5 06-cloud-infrastructure-and-configuration.md records the management-provided AWS and Google Cloud deployment configuration, limitations, and evidence still required.
- 6 07-backup-and-restore-configuration.md records the management-provided backup configuration, current gaps, and required remediation.
- 7 ../FORTVAULT_CUSTODY_TECHNICAL_OVERVIEW.md describes custody architecture and trust boundaries.
- 8 ../FORTVAULT_EXCHANGE_TECHNICAL_OVERVIEW.md describes the current read-only exchange-integration scope.

Prepared Package Contents

The generated evidence directory contains:

- a package index and evidence register;
- separate FortVault and FortX component architecture diagrams;
- a combined FortVault/FortX platform architecture;
- custody and exchange technical overviews;
- source-controlled testing, health-check, logging, secret-handling, and encryption evidence;
- a README and architecture sharing index;
- sanitized examples from selected component GitHub READMEs;
- a management-provided AWS and Google Cloud configuration summary;
- a management-provided backup and restore configuration summary;
- a sanitized cloud deployment and network-boundary diagram;
- an operational evidence checklist identifying information that source code cannot prove; and
- a plain-text covering email draft.

Cloud and backup current-state descriptions are included, but they are not substitutes for cloud-console evidence or proof that controls operated effectively. Centralized production logging, production TLS/encryption settings, endpoint management, release-specific test output, approved recovery objectives, and restore-test evidence remain pending.

Current Material Gaps

- Cloud audit logging and centralized infrastructure monitoring are not configured.
- Infrastructure is configured manually; infrastructure-as-code is not yet implemented.
- Backup protection is not cross-region, cross-account, immutable, or protected against deletion.

- Recovery point objective (RPO) and recovery time objective (RTO) are not approved.
- No successful restore test has been recorded.
- Backup administration permits creation, modification, deletion, and restore by the same administrator role; least privilege and separation of duties require review.

Handling Rules

- Redact credentials, access tokens, private keys, seed phrases, MPC shares, secret-store values, private addresses, customer information, and internal-only endpoints.
- Provide screenshots from the relevant production account or management system only after reviewing them for sensitive information.
- Do not treat a repository README, Docker Compose file, or development configuration as proof of the production environment.
- Record the source, owner, date collected, environment, and reviewer for every operational evidence item.